

PASTA Threat Model Report

Project: Sneaker Marketplace Mobile Application

Executive Summary: This document outlines the threat modeling process for the upcoming Sneaker Marketplace mobile application using the Process for Attack Simulation and Threat Analysis (PASTA) methodology. The objective is to identify security requirements, mitigate vulnerabilities, and ensure compliance with online payment standards (PCI-DSS) prior to launch.

Stages I - IV

I. Define business and security objectives	- Facilitate secure connections and transactions between sellers and buyers. - Ensure the strict protection of users' personal information. - Provide a secure environment for online payments. - Maintain compliance with industry security standards, including PCI-DSS.
II. Define the technical scope	Critical infrastructure components include: APIs: Essential for handling requests between the mobile app, external services, and databases. High priority due to their broad attack surface. SQL Database: Facilitates structured storage of users' personal information and inventory. Cryptographic Standards (SHA-256, AES, PKI): Crucial for ensuring data integrity, protecting passwords, and securing financial transactions (PCI-DSS requirement).
III. Decompose application	<i>Reference: Data flow diagram</i> The primary data flow involves a User initiating a Product search process ("Searching for sneakers for sale"), which queries the Database to return "Listings of current inventory."
IV. Threat analysis	Identified threats targeting the application's handled data: SQL Injection: Attackers targeting the database to extract confidential customer information (orders, addresses, emails, phone numbers). Session Hijacking: Attackers targeting user sessions to gain unauthorized access to buyers' and sellers' accounts.

Stages V - VII

V. Vulnerability analysis	Identified vulnerabilities that could be exploited by the threats above: • Lack of prepared statements: Leaves the SQL database vulnerable to injection attacks. • Weak login credentials: Susceptible to brute-force attacks, facilitating session hijacking.
VI. Attack modeling	<i>Reference: Sample attack tree diagram</i> The attack model maps out how "User data" is compromised either via "SQL injection" (due to a "Lack of prepared statements") or via "Session hijacking" (due to "Weak login credentials").
VII. Risk analysis and impact	Security controls and requirements to mitigate identified risks: • Prepared Statements: Implementing parameterized queries will protect the database, users, and company reputation from SQL injection attacks. • Authentication Policies: Using Multi-Factor Authentication (MFA) and enforcing strong, unique passwords reduces the risk of credential stuffing and session hijacking. • Data Encryption & PCI-DSS: Employing robust encryption (AES/SHA-256) protects sensitive cardholder data (PAN, CVV) during transit and at rest. • Principle of Least Privilege: Restricting access to the database at the architectural level ensures confidentiality of personal data.